

Banking Security, Reliability and Operations

Reference for security, auditability and failure handling.

Authentication and Authorization

Authentication establishes identity; authorization checks permissions.

RBAC can separate customer, employee, administrator and auditor capabilities.

Server-side authorization is mandatory; frontend checks alone are insufficient.

Financial Security

Passwords must be securely hashed. Tokens and secrets must not be logged.

Sensitive data should be minimized and masked in logs.

Rate limiting can protect login, OTP and payment endpoints.

Idempotency protects financial operations from duplicate retries.

Reliability

Retries should be bounded and designed around idempotency.

Dead-letter queues isolate repeatedly failing messages.

Timeouts and circuit breakers can reduce cascading failures.

Health and readiness checks help determine whether services can receive traffic.

Auditability

Financial actions should have correlation identifiers and auditable state transitions.

Audit records should capture actor, action, resource, timestamp, result and reference IDs without exposing secrets.

Operations

Settlement finalizes simulated inter-bank obligations.

Reconciliation compares records to detect mismatches.

Ambiguous transactions should be resolved through authoritative records rather than inferred from a timeout alone.